

ชุดทดลองการเจาะระบบผ่านเว็บ

นายวันประชา นวนสร้อย

นายชัชวาลย์ เตปิน

ปริญญานิพนธ์นี้เป็นส่วนหนึ่งของการศึกษาตามหลักสูตรปริญญาวิศวกรรมศาสตรบัณฑิต

สาขาวิชาวิศวกรรมคอมพิวเตอร์

คณะวิศวกรรมศาสตร์

สถาบันเทคโนโลยีพระจอมเกล้าเจ้าคุณทหารลาดกระบัง

พ.ศ.2548

ชุดทดลองการเจาะระบบผ่านเว็บ

โดย

นายวันประชา นวนสร้อย

นายชัชวาลย์ เตปิน

อาจารย์ที่ปรึกษา

อ. ธนัญชัย ตรีภาค

อ. อัครเดช วัชรภูพวงษ์

ผศ. ธนา หงษ์สุวรรณ

ปริญญานิพนธ์นี้เป็นส่วนหนึ่งของการศึกษาตามหลักสูตรปริญญาวิศวกรรมศาสตรบัณฑิต

สาขาวิชาวิศวกรรมคอมพิวเตอร์

คณะวิศวกรรมศาสตร์

สถาบันเทคโนโลยีพระจอมเกล้าเจ้าคุณทหารลาดกระบัง

พ.ศ.2548

ปริญญานิพนธ์ปีการศึกษา 2548

ภาควิชาวิศวกรรมคอมพิวเตอร์

คณะวิศวกรรมศาสตร์ สถาบันเทคโนโลยีพระจอมเกล้าเจ้าคุณทหารลาดกระบัง

เรื่อง ชุดทดลองเจาะระบบผ่านเว็บ

Web Hacking Sandbox

ผู้จัดทำ

1. นายวันประชา นวนสร้อย รหัสนักศึกษา 46015371

2. นายชัชวาลย์ เตปิ่น รหัสนักศึกษา 46015343

(อาจารย์ ชาญชัย ตรีภาค)

อาจารย์ที่ปรึกษา

(อาจารย์ อัครเดช วัชรเทพวณิช)

อาจารย์ที่ปรึกษา

(ผศ. ธนา หงษ์สุวรรณ)

อาจารย์ที่ปรึกษา

ชุดทดลองเจาะระบบผ่านเว็บ

นายวันประชา นวนสร้อย	46015371
นายชัชวาลย์ เตปิน	46015343
อ. ธนัญชัย ตริภาค	อาจารย์ที่ปรึกษา
อ. อัครเดช วัชรภูพงษ์	อาจารย์ที่ปรึกษาร่วม
ผศ. ธนา หงส์สุวรรณ	อาจารย์ที่ปรึกษาร่วม
ปีการศึกษา 2548	

บทคัดย่อ

เนื่องด้วยการขยายตัวของอินเทอร์เน็ตเพิ่มขึ้นอย่างมากซึ่งยังมีผู้ใช้งานอินเทอร์เน็ตจำนวนมากที่ยังขาดความรู้เกี่ยวกับการเจาะระบบผ่านเว็บ จึงทำให้เกิดโครงการนี้ขึ้นมาซึ่งแท้ที่จริงแล้วโครงการนี้นั้นให้ความรู้กับบุคคลภายในองค์กร ซึ่งจุดประสงค์สำคัญคือการรู้จักป้องกันตัวเองจากเหล่าผู้ไม่หวังดี แต่การป้องกันนั้นจะทำได้ก็ต่อเมื่อเรารู้ว่าเหล่าผู้ไม่หวังดีนั้นสามารถทำอะไรได้บ้าง

ทางโครงการจึงทำเป็นเว็บที่ให้ความรู้เกี่ยวกับการเจาะระบบผ่านเว็บ และมีหน้า Sandbox ซึ่งเป็นหน้าที่ไว้สำหรับการทดลองและการป้องกันเพื่อความเข้าใจมากยิ่งขึ้นซึ่งเป็นวิธีที่ได้รับความนิยมจากเหล่าผู้ไม่หวังดีคือSQL Injection, Hidden Manipulation , Java Injection , Cross Site Script(XSS) , Session Hijacking , Query Poisoning , Parameter Tempering , Application Buffer Overflowsแต่ถึงกระนั้นก็ตามกลวิธีการเจาะระบบผ่านเว็บนั้นเปลี่ยนแปลงไปตามเทคโนโลยีเช่นกันจึงหวังว่าผู้ศึกษาควรต้องติดตามกรรมวิธีในการเจาะระบบผ่านเว็บอยู่เสมอๆ

Web Hacking Sandbox

Wanpracha Nuansoi	46015371
Chadchawan Teapin	46015343
Thanunchai Tripak	Advisor
Akkradach Wantcharapupung	Co-Advisor
Tana Hongsuwan	Co-Advisor
Academic Year 2004	

ABSTRACT

Despite the rapid increase of internet usage, a lot of internet users still lack knowledge concerning the system penetration via web; therefore, this Project is set up. In fact, this Project focuses on providing the person working within the organization with knowledge. The key purpose is to protect oneself from ill-wished people, but such protection can be succeeded only when one knows what those people can do.

That is why the web has been created in the Project for providing knowledge concerning penetrating system via web; and there is Sandbox page for testing and protecting and for more understanding; that are the popular methods done by ill-wished people including SQL Injection, Hidden Manipulation, Java Injection, Cross Site Script (XSS), Session Hijacking, Query Poisoning, Parameter Tempering, Application Buffer Overflows. Nevertheless, the ways of penetrating system via web change according to technology of web as well. So, I do hope that the learner should always keep up with those methods of penetrating system via web.

กิตติกรรมประกาศ

I would like to express my deeply many thanks to Thanunchai Treepark of Computer Engineering Department, Faculty of Engineering, King Mongkut's Institute of Technology Ladkrabang, Thailand, for all advises and very good support me concerning about my paper and thesis.

วิทยานิพนธ์ฉบับนี้สำเร็จได้อย่างดี ด้วยคำแนะนำ และคำปรึกษาจาก อ. ธนัญชัย ตรีภาค ซึ่งเป็นอาจารย์ผู้ควบคุมวิทยานิพนธ์ อ. อัครเดช วัชรเทพวณิช และ ผศ.ธนา หงส์สุวรรณ ข้าพเจ้ารู้สึกซึ่งในความอนุเคราะห์จากท่านอาจารย์ทั้งสองท่าน และขอขอบพระคุณเป็นอย่างสูง

ขอกราบพระคุณคณาจารย์ภาควิชาวิศวกรรมคอมพิวเตอร์ คณะวิศวกรรมศาสตร์ สถาบันเทคโนโลยีพระจอมเกล้าเจ้าคุณทหารลาดกระบัง ทุก ๆ ท่านที่ได้ประสิทธิ์ประสาทวิชาให้กับข้าพเจ้า

ขอขอบคุณห้องวิจัย ISAG ภาควิชาวิศวกรรมคอมพิวเตอร์ ที่ได้สนับสนุนเครื่องมือ ตลอดจนข้อมูล และหนังสือต่างๆ ที่ใช้ในการทำวิจัย

ขอขอบคุณเพื่อนๆ พี่ๆ น้องๆ ในภาควิชาวิศวกรรมคอมพิวเตอร์ สถาบันเทคโนโลยี พระจอมเกล้าเจ้าคุณทหารลาดกระบัง ทุกคนที่ให้คำแนะนำต่างๆ และคอยให้กำลังใจเสมอมา

ขอขอบคุณบัณฑิตศึกษาและบัณฑิตวิทยาลัย คณะวิศวกรรมศาสตร์ที่ให้ความช่วยเหลือ ในเรื่องต่างๆ

สุดท้ายนี้ข้าพเจ้าขอกราบขอบพระคุณ บิดา มารดา และครอบครัวของข้าพเจ้าที่เป็นกำลังใจ และให้การสนับสนุนในทุกเรื่องๆ ทำให้ข้าพเจ้าสามารถทำวิทยานิพนธ์ฉบับนี้สำเร็จลุล่วงด้วยดี

คุณค่าและประโยชน์อันพึงมาจากวิทยานิพนธ์ฉบับนี้ ข้าพเจ้าขอบแต่ผู้มีพระคุณทุกท่าน

นายวันประชา นวนสร้อย

นายชัชวาลย์ เตปิน

สารบัญ

หน้า

บทคัดย่อภาษาไทย.....	I
บทคัดย่อภาษาอังกฤษ.....	II
กิตติกรรมประกาศ.....	III
สารบัญ.....	IV
สารบัญตาราง.....	VIII
สารบัญรูป.....	IX
บทที่ 1 บทนำ.....	1
1.1 ความสำคัญและที่มาของโครงการ.....	1
1.2 วัตถุประสงค์ของโครงการ.....	1
1.3 ขอบเขตของโครงการ.....	2
1.4 วิธีการดำเนินการ.....	2
1.5 ประโยชน์ที่คาดว่าจะได้รับ.....	3
1.6 ส่วนประกอบของปริญญานิพนธ์.....	3
บทที่ 2 ทฤษฎีพื้นฐานที่ใช้ในการวิจัยชุดทดลองเจาะระบบผ่านเว็บ.....	4
2.1 สถาปัตยกรรมของเว็บ.....	4
2.1.1 1-tier.....	4
2.1.2 2-tier.....	5
2.1.3 3-tier.....	6
2.2 HTTP Protocol.....	8
2.2.1 HTTP.....	9
2.2.2 HTTP/0.9.....	9
2.2.3 HTTP/1.0.....	9
2.2.4 HTTP/1.1.....	9
2.2.5 HTTP Request.....	10
2.2.6 HTTP Response.....	11

สารบัญ (ต่อ)

หน้า

2.3	Web Server.....	11
2.3.1	Web Server.....	11
2.3.2	Apache.....	11
2.3.3	Internet Information Server (IIS).....	12
2.4	Database Server.....	14
2.5	Web Language.....	15
2.5.1	HTML.....	15
2.5.2	PHP.....	18
2.5.3	Java Script.....	20
2.6	Uniform Resource Locator (URL).....	23
2.6.1	โครงสร้างของ URL.....	24
2.6.2	URLs และการส่งผ่านพารามิเตอร์.....	25
2.6.3	การเ็นโค้ด URL (URL Encoding).....	28
2.6.4	ตัวอักขระเมต้า (Meta-characters).....	29
2.6.5	การระบุตัวอักขระพิเศษบนสตริง URL.....	29
2.6.6	การเ็นโค้ดด้วยฟอร์มเมตของยูนิโค้ด (Unicode Encoding).....	30
บทที่ 3	ทฤษฎีการเจาะระบบผ่านเว็บ.....	31
3.1	SQL Injection.....	34
3.2	Hidden Manipulation.....	35
3.3	Java Injection.....	36
3.3.1	Injection Basics.....	36
3.3.2	Java Injection Form Editing.....	37
3.3.3	Java Injection Cookie Editing.....	38
3.4	Cross Site Scripting (XSS).....	39
3.5	Query Poisoning.....	41
3.6	Session Hijacking.....	44
3.7	Parameter Tampering.....	46
3.8	Application Buffer Overflows.....	47

บทที่ 4 การออกแบบและพัฒนาโครงงาน	50
4.1 SQL Injection	51
4.2 Hidden Manipulation.....	52
4.3 Java Injection.....	53
4.4 Cross Site Scripting (XSS).....	54
4.5 Query Poisoning.....	57
4.6 Session Hijacking.....	59
4.7 Application Buffer Overflows.....	61
4.8 Parameter Tempering.....	62
บทที่ 5 การทดลองและผลการทดลอง.....	63
5.1 SQL Injection.....	63
5.2 Hidden Manipulation.....	64
5.3 Java Injection.....	67
5.3.1 Java Injection Form Editing.....	67
5.3.2 Java Injection Cookie Editing.....	68
5.4 Cross Site Script (XSS).....	70
5.5 Query Poisoning.....	73
5.6 Session Hijacking.....	77
5.7 Application Buffer Overflows.....	80
5.8 Parameter Tempering.....	81
บทที่ 6 เครื่องมือช่วยเหลือ.....	83
6.1 Netcat.....	83
6.2 Whisker.....	84
6.3 Brutus.....	85
6.4 Achilles.....	86
6.5 Cookie Pal.....	87
6.6 Teleport Pro.....	88
บทที่ 7 บทวิจารณ์และสรุป.....	90
7.1 บทสรุป.....	90

7.2	วิจารณ์สิ่งที่ได้จากโครงงาน.....	90
7.3	ปัญหาอุปสรรคและแนวทางแก้ไข.....	91
7.4	แนวทางการพัฒนาต่อ.....	91
	บรรณานุกรม.....	92
	ภาคผนวก.....	93
	ภาคผนวก ก. ตารางแสดงพอร์ตของเซิร์ฟเวอร์ตามมาตรฐาน HTTP/1.1.....	93
	ภาคผนวก ข. ตารางแสดงเครื่องมือที่เกี่ยวกับความปลอดภัยของเว็บ.....	95

สารบัญตาราง

ตารางที่	หน้า
2.1 รายละเอียดของเมธอดของโปรโตคอล HTTP/1.0.....	10
2.2 คำสั่ง SQL	14
2.3 แอตทริบิวต์และผลกระทบต่อความปลอดภัย.....	16
2.4 องค์ประกอบของ URL.....	24
2.5 ตัวอักขระพิเศษและความหมายของมันภายใน URL.....	28
3.1 ช่องโหว่ของการเกิด SQL Injection.....	35
3.2 ช่องโหว่ของการเกิด XSS.....	41
3.3 ช่องโหว่ของการเกิด Buffer Overflow.....	49
ก.1 ลิสต์รายการพอร์ตของเซิร์ฟเวอร์ตามมาตรฐาน HTTP/P/1.1.....	93
ข.2 เครื่องมือที่เกี่ยวข้องกับความปลอดภัยของเว็บ.....	95

สารบัญรูป

รูปที่	หน้า
2.1 สถาปัตยกรรมของเว็บ.....	4
2.2 สถาปัตยกรรม 1-tier และ 2 tier	5
2.3 สถาปัตยกรรม 3-tier	6
2.4 รูปแบบของการติดตั้ง Web Application.....	7
2.5 รูปแบบการติดต่อผ่าน HTTP Protocol	8
2.6 ตัวอย่างของ URL	25
3.1 ประโยชน์ของ Firewall	31
3.2 ประโยชน์ของ Firewall.....	32
3.3 ประโยชน์ของ Firewall	33
3.4 การเจาะระบบผ่านเว็บที่ Firewall ไม่สามารถป้องกันได้.....	33
3.5 การเจาะระบบผ่านเว็บที่ firewall ไม่สามารถป้องกันได้.....	34
4.1 ขั้นตอนการดำเนินโครงการ.....	50
4.2 การทำ SQL Injection	51
4.3 SQL Injection test	51
4.4 การทดสอบ Hidden Manipulation	52
4.5 การเกิด Cross Site Script (XSS).....	54
4.6 การตั้งกระทู้.....	55
4.7 ลำดับการทำ Query Poisoning	57
4.8 การรับ Query String เพื่อติดต่อฐานข้อมูล.....	58
4.9 การใส่ Statement SQL เพิ่มใน Query String	58
4.10 ลำดับการทำ Reverse engineering เพื่อจะขโมย Session	59
4.11 การเกิดช่องโหว่ของการเกิด Application Buffer Overflows.....	61
5.1 หน้า login ในเทคนิค SQL Injection	63
5.2 การผ่านระบบ login ด้วย SQL Statement.....	63
5.3 การ login ระบบผ่านด้วย SQL Injection สำเร็จ	64
5.4 การป้องกันการทำ SQL Injection	64
5.5 การสั่งซื้อจำนวน 5 ชิ้นซึ่งไม่ได้ทำการแก้ราคา.....	65
5.6 การสั่งซื้อจำนวน 5 ชิ้นในราคา 1 บาท.....	65
5.7 การสั่งซื้อจำนวน 5 ชิ้น.....	66

สารบัญรูป (ต่อ)

รูปที่	หน้า
5.8 การเปลี่ยนค่า field ภายในเครื่อง Client และค่าที่เปลี่ยน.....	67
5.9 การส่งค่าที่เปลี่ยนไปประมวลผลที่ Server.....	67
5.10 การดูค่า Cookie.....	68
5.11 เป็นการเปลี่ยนค่า Cookie.....	68
5.12 ค่า Cookie ซึ่งไม่การเก็บค่า Cookie ที่เป็น Clear text.....	69
5.13 การทำ Java Injection แต่ถูกป้องกันเอาไว้แล้วจึงไม่ alert ขึ้นมา	69
5.14 การส่งซื้อสินค้าที่ไม่มีการใช้ Hidden field ในการเก็บราคา ราคาจึงไม่เปลี่ยน.....	70
5.15 การทดสอบอย่างง่ายว่าเว็บบอร์ดวาง Script ได้หรือไม่.....	70
5.16 การวางกระตุ้เพื่อทดสอบ Script.....	71
5.17 กระตุ้ที่ได้วางไว้.....	71
5.18 การ วางกระตุ้ที่จะแสดงค่า Cookie.....	71
5.19 ค่า Cookie เมื่อคลิกกระตุ้.....	72
5.20 กระตุ้ที่ได้วาง Script เพื่อขโมย Cookie.....	72
5.21 ค่า Cookie ที่ถูกขโมย.....	72
5.22 กระตุ้ที่ได้วางไว้แต่เว็บบอร์ดไม่สามารถวาง Script ได้.....	72
5.23 การทดสอบการทำ Query Poisoning.....	73
5.24 ทำ Query Poisoning โดยใช้ Statement “ORDER BY Price DESC”.....	74
5.25 ทำ Query Poisoning โดยใช้เทคนิคการ UNION.....	74
5.26 การป้องกันการทำให้ Query Poisoning.....	75
5.27 หน้าเว็บดาวโหลดที่ Login ด้วย User ธรรมดา.....	76
5.28 ผลของ Login ด้วย User ธรรมดาซึ่งไม่สามารถดาวโหลดได้.....	77
5.29 หน้าการเปลี่ยนแปลงค่า Session ไปเป็น User ชื่อ Trudy.....	77
5.30 หน้าที่ได้ทำการขโมย Session ของ Trudy ได้เป็นผลสำเร็จ.....	77
5.31 การให้ข้อมูลการป้องกัน Session Hijacking.....	78
5.32 การทำ Application Buffer Overflows.....	79
5.33 ผลของการป้องกันการทำให้ Application Buffer Overflows.....	79
5.34 หน้าการให้ความรู้และถึงทำการทดลองของ Parameter Tempering.....	80
5.35 เทคนิคการทำ Parameter tempering แบบ cookie.....	80
5.36 เทคนิคการทำ Parameter tempering แบบ Form Field.....	81
5.37 เทคนิคการทำ Parameter tempering แบบ URL Query Strings	81

5.38 เทคนิคการทำ Parameter tempering แบบ HTTP Headers	82
5.39 หน้าการป้องกันของ Parameter Tempering.....	82
6.1 การใช้ Netcat.....	83
6.2 โปรแกรม Whisker.....	84
6.3 โปรแกรม Brutus.....	85
6.4 โปรแกรม Achilles.....	86
6.5 โปรแกรม Cookie Pal Alert.....	87
6.6 หน้าจอของ Cookie Pal.....	88
6.7 โปรแกรม Teleport Pro.....	89